
SENAC — FACULDADE DE TECNOLOGIA
Curso de Análise e Desenvolvimento de Sistemas

AUDITORIA DE SISTEMAS DE INFORMAÇÃO

Relatório Integrado — Sprints 1 a 6

Disciplina: Métricas e Auditoria de Software

Integrantes do Grupo G1

Arthur Zavoudakis
Michael Gouveia
Ruimar Cleto

São Paulo — 2026

SUMÁRIO

SUMÁRIO	2
1. Introdução à Auditoria de Sistemas	4
1.1 Evolução Histórica	4
1.2 Conceito e Definição	4
1.3 Importância nas Organizações	5
2. Auditoria Interna e Externa de TI	5
2.1 Auditoria Interna	5
2.2 Auditoria Externa	5
2.3 Quadro Comparativo	6
3. Função do Auditor e Técnicas de Auditoria	6
3.1 Perfil Profissional	6
3.2 Técnicas de Auditoria	7
4. Controles Internos, Conformidade e Lei SOX	7
4.1 Framework COSO	7
4.2 Contexto Histórico da Lei SOX	8
4.3 Impacto da SOX na TI	8
5. Frameworks Globais de Governança e Segurança	8
5.1 COBIT 2019	8
5.2 ISO/IEC 27001:2022	9
5.3 NIST Cybersecurity Framework	9
5.4 Controles Gerais de TI (ITGC) e Controles de Aplicação (ITAC)	9
6. CMM, CMMI e Maturidade de Processos	9
6.1 Origem do CMM	10
6.2 Evolução para o CMMI	10
7. MPS.BR, SPICE e Normas de Qualidade	10
7.1 O Projeto SPICE e as Normas ISO	10
7.2 O MPS.BR	11
8. Auditoria no Ciclo de Vida de Desenvolvimento de Software (SDLC)	11
8.1 Fases do SDLC e Checkpoints de Auditoria	12
8.2 DevSecOps e Auditoria Contínua	12
8.3 Controles Críticos no SDLC	12
9. Análise Crítica da Auditoria de Sistemas	13
9.1 Desafios de Implementação	13
9.2 Limitações do Processo	13
9.3 Riscos de Não Conformidade	13
9.4 Auditoria Tradicional vs. Auditoria Contínua	13
10. Estudo de Casos Práticos	14
10.1 Caso 1 — Fraude Fiscal por Manipulação de Notas Fiscais	14
Descrição do Caso	14
Classificação Normativa	14
Limitações dos Sistemas Tradicionais e o Papel da IA	14
Lições Aprendidas	15

10.2 Caso 2 — Falhas de Conformidade com a LGPD	15
Descrição do Caso	15
Exposição à LGPD	15
Lições Aprendidas e Ações Corretivas	15
11. Conclusão	16
12. Referências Bibliográficas	16

1. Introdução à Auditoria de Sistemas

A rápida transformação digital e a consolidação dos ambientes computacionais híbridos impuseram uma reestruturação profunda nas metodologias de governança e controle corporativo. A auditoria de sistemas de informação emerge como uma disciplina crítica destinada a avaliar se a infraestrutura tecnológica e as aplicações de software atendem aos princípios de segurança, integridade, confidencialidade e disponibilidade, protegendo os ativos organizacionais contra vulnerabilidades crescentes.

Embora reconhecida hoje por seu alto teor tecnológico, a auditoria possui raízes históricas que remontam a mais de 5.000 anos antes de Cristo, com manifestações rudimentares de controle de produções agrícolas, tesouros reais e arrecadação de tributos no Egito e na Suméria. O termo "auditor" (do latim *audire*, "aquele que ouve") foi formalizado no século XIII, quando o rei Eduardo I designou um funcionário para examinar as contas de sua falecida esposa, consolidando a natureza contábil e fiscal da profissão.

Com o advento do processamento eletrônico de dados no século XX, as trilhas físicas de papel foram substituídas por registros intangíveis, forçando a reformulação da disciplina para o que hoje se denomina Auditoria de Tecnologia da Informação (TI).

1.1 Evolução Histórica

A auditoria de sistemas surgiu na década de 1960 com a introdução dos primeiros computadores de grande porte (mainframes) nas organizações. Inicialmente, o foco era puramente contábil — a chamada "auditoria através do computador" —, verificando se os cálculos gerados estavam corretos.

Com o avanço tecnológico, o surgimento da internet e a descentralização dos sistemas, o foco migrou para a governança de TI, avaliação de riscos de segurança da informação e conformidade com regulamentações internacionais. Conforme traçado por Cannavale (2021), a linha do tempo parte dos anos 1960 (foco em PED — Processamento Eletrônico de Dados), passa pela avaliação de redes nos anos 1990 e chega ao cenário atual centrado em segurança cibernética e computação em nuvem.

1.2 Conceito e Definição

De acordo com as definições consolidadas pelo Guia de Auditoria de TI da Organização Internacional das Entidades de Fiscalização Superiores (INTOSAI), a auditoria de TI compreende um exame e revisão sistemática dos sistemas de informação e de seus controles relacionados. Esse processo visa obter segurança razoável e atestar a conformidade das ferramentas tecnológicas com as reais necessidades organizacionais.

Sob a perspectiva operacional, a auditoria de sistemas de informação atua na revisão e avaliação contínua dos controles lógicos, infraestrutura física, operações de dados, desempenho de servidores e procedimentos de segurança que suportam as decisões estratégicas do negócio. No contexto nacional, o Tribunal de Contas da União (TCU) consolidou ampla jurisprudência subordinando a segurança da informação à governança geral de TI, reforçando a auditoria de sistemas como instrumento indispensável de controle externo.

1.3 Importância nas Organizações

A necessidade de auditoria de sistemas manifesta-se de forma crítica especialmente em pequenas e médias empresas (PMEs), que frequentemente subestimam os riscos associados à conexão com redes globais e desconhecem o valor real dos dados que armazenam. O fator humano emerge como o elemento de maior vulnerabilidade nessas estruturas: investimentos em segurança tecnológica tornam-se ineficazes se os colaboradores não forem continuamente treinados e conscientizados a respeito de ameaças como a engenharia social.

Assim, a auditoria de sistemas deve transcender a análise de códigos e hardwares, avaliando também a eficácia dos programas de treinamento em segurança da informação.

2. Auditoria Interna e Externa de TI

As auditorias de sistemas subdividem-se em duas categorias complementares, cujos propósitos e públicos-alvo operam em dimensões distintas do controle corporativo.

2.1 Auditoria Interna

A auditoria interna de TI foca na melhoria contínua dos controles internos, gestão de riscos e processos operacionais, servindo como uma ferramenta estratégica preventiva para a alta administração e colaboradores. Conduzida por profissionais da própria empresa ou consultores contratados, goza de maior flexibilidade de cronograma e deve ser realizada preferencialmente de forma anual, antecipando-se à auditoria externa. Seu escopo técnico é balizado pela NBC TI 01 e pelas diretrizes internacionais do Institute of Internal Auditors (IIA).

2.2 Auditoria Externa

Em contrapartida, a auditoria externa (ou independente) visa conferir transparência, credibilidade e fé pública às demonstrações contábeis e à robustez dos controles que suportam as transações financeiras. Regulada pela NBC TA 200, pelas normas do PCAOB

e do AICPA, é executada por terceiros totalmente independentes e sem vínculo com a organização. Suas conclusões destinam-se tanto à governança interna quanto a stakeholders externos, como investidores, acionistas, credores e agências reguladoras.

2.3 Quadro Comparativo

Elemento	Auditoria Interna	Auditoria Externa
Vínculo Profissional	Colaborador da empresa ou consultor interno	Profissional independente, sem vínculo com a organização
Objetivo Principal	Avaliar processos e mitigar riscos operacionais	Emitir parecer independente sobre conformidade regulatória
Público-Alvo	Diretoria, Conselho e Comitê de Auditoria	Investidores, acionistas, órgãos reguladores
Periodicidade	Contínua, com flexibilidade de cronograma	Periódica (geralmente anual), ligada ao exercício fiscal
Padrões Normativos	NBC TI 01 e IPPF do IIA	NBC TA 200, PCAOB e AICPA (SOC 1, 2, 3)

3. Função do Auditor e Técnicas de Auditoria

O papel do auditor de TI transcende a mera verificação de conformidade. Ele atua como um parceiro estratégico que assessora os gestores de TI e a alta liderança na governança e na gestão dos recursos tecnológicos, avaliando se a alocação de investimentos reflete a estratégia corporativa.

3.1 Perfil Profissional

O auditor de sistemas deve possuir independência, ceticismo profissional e capacidade analítica, conforme discutido por Attie (2018). Para garantir a qualidade e padronização de suas atividades, deve fundamentar seu trabalho nas diretrizes profissionais do ITAF da ISACA, da norma AS 2101 do PCAOB, das seções de auditoria do AICPA (AU-C 300) e do IPPF do IIA.

No campo comportamental, o auditor de sistemas de informação deve pautar-se nas sete diretrizes do Código de Ética Profissional da ISACA:

- Apoio aos Padrões: incentivar o cumprimento das normas e procedimentos recomendados.
- Objetividade e Diligência: executar as atividades com isenção e ceticismo profissional.
- Conduta Ética e Honestidade: atuar em conformidade com as leis vigentes.
- Confidencialidade e Privacidade: proteger o sigilo das informações coletadas.

- Manutenção da Competência: manter-se em constante atualização profissional.
- Transparência no Reporte: comunicar de forma clara todos os achados de auditoria.
- Promoção da Conscientização: auxiliar stakeholders no entendimento das boas práticas.

3.2 Técnicas de Auditoria

O papel do auditor de TI deixou de ser o de um mero "fiscal" de processos após o fechamento do exercício para se tornar um parceiro estratégico de riscos. Antigamente, as técnicas baseavam-se em amostragem em papel e entrevistas. Hoje, o auditor utiliza ferramentas de software avançadas para analisar 100% das transações de um banco de dados.

As principais técnicas modernas incluem:

- TAATs (Técnicas de Auditoria Assistidas por Computador): uso de ferramentas automatizadas para cruzamento e análise de grandes volumes de dados.
- Análise de Big Data: processamento e interpretação de bases de dados massivas para identificar padrões e anomalias.
- Auditoria Contínua: monitoramento em tempo real baseado em análise de logs gerados continuamente pelos sistemas.
- Pentests (Testes de Invasão): simulação controlada de ataques cibernéticos para identificar vulnerabilidades nos controles de segurança.
- Análise de Vulnerabilidades: varredura automatizada de sistemas em busca de falhas de segurança conhecidas.

4. Controles Internos, Conformidade e Lei SOX

Os controles internos de TI constituem o conjunto de políticas, procedimentos e mecanismos implementados para proteger os ativos de informação, garantir a integridade dos dados e assegurar a conformidade com normas e regulamentações vigentes.

4.1 Framework COSO

O COSO (Committee of Sponsoring Organizations of the Treadway Commission), em seu Internal Control — Integrated Framework (2013), estabelece os cinco componentes essenciais do controle interno:

- Ambiente de Controle: fundamento cultural e ético que permeia toda a organização.
- Avaliação de Riscos: identificação e análise dos riscos relevantes para o atingimento dos objetivos.
- Atividades de Controle: políticas e procedimentos que asseguram a execução das diretrizes da administração.
- Informação e Comunicação: sistemas para capturar e comunicar informações relevantes.
- Monitoramento: avaliação contínua da qualidade do desempenho dos controles internos.

4.2 Contexto Histórico da Lei SOX

No início dos anos 2000, grandes corporações americanas como a Enron e a WorldCom utilizaram brechas na contabilidade e manipulação de sistemas de informação para ocultar dívidas bilionárias e inflar lucros falsos. O colapso dessas empresas destruiu a confiança do mercado financeiro global.

Como resposta direta a esses escândalos, em 2002, os senadores Paul Sarbanes e Michael Oxley criaram a Lei Sarbanes-Oxley (SOX). Como os dados financeiros passam obrigatoriamente pelos sistemas de informação, a TI tornou-se o pilar central para garantir que as informações financeiras fossem auditáveis, seguras e livres de adulteração.

4.3 Impacto da SOX na TI

A Lei SOX impactou diretamente a TI principalmente por meio de suas seções 302 e 404:

- Seção 302: exige que o CEO e o CFO atestem pessoalmente a eficácia dos controles internos sobre os relatórios financeiros.
- Seção 404: determina que a administração avalie anualmente a eficácia dos controles internos sobre relatórios financeiros, com verificação independente por auditor externo.

Esses requisitos tornaram mandatória a implementação de controles de TI robustos, especialmente no que tange à gestão de acessos, trilhas de auditoria (logs), controle de mudanças e segregação de funções nos sistemas que processam dados financeiros.

5. Frameworks Globais de Governança e Segurança

A análise da maturidade dos controles de TI requer o alinhamento com frameworks internacionais reconhecidos. Os principais modelos adotados globalmente são o COBIT 2019, a ISO/IEC 27001:2022 e o NIST Cybersecurity Framework.

5.1 COBIT 2019

O COBIT 2019, desenvolvido pela ISACA, representa a estrutura de governança mais abrangente do mercado. Ele diferencia de maneira categórica os sistemas de governança — responsáveis por avaliar, dirigir e monitorar os objetivos estratégicos pelo domínio EDM — dos sistemas de gestão, focados no planejamento, construção, entrega e monitoramento operacional pelos domínios APO, BAI, DSS e MEA.

O COBIT aborda cinco áreas de foco fundamentais: alinhamento estratégico, entrega de valor, gestão de recursos, gerenciamento de risco e medição de desempenho. Em sua versão 2019, o framework adotou um modelo de atualização contínua colaborativo

(open-source), maior flexibilidade para aplicação em projetos específicos e forte foco em capacitação profissional.

5.2 ISO/IEC 27001:2022

A ISO/IEC 27001:2022 define as especificações para o estabelecimento de um Sistema de Gestão de Segurança da Informação (SGSI) baseado na tríade de confidencialidade, integridade e disponibilidade. A norma organiza seus controles em domínios estruturados, incluindo políticas de segurança, segurança de recursos humanos, gestão de ativos, controle de acesso físico e lógico, criptografia e segurança operacional.

A sinergia entre o COBIT 2019 e a ISO 27001 ocorre por meio do mapeamento de seus processos, permitindo que o ciclo Plan-Do-Check-Act (PDCA) da ISO forneça as especificações técnicas de segurança exigidas pelas diretrizes estratégicas do COBIT.

5.3 NIST Cybersecurity Framework

O NIST Cybersecurity Framework provê uma abordagem prática para a resiliência cibernética, estruturada em cinco pilares fundamentais: Identificar, Proteger, Detectar, Responder e Recuperar. Embora amplamente adotado, pode representar uma sobrecarga operacional desnecessária para empresas de pequeno porte devido ao rigor e à complexidade de seus requisitos, tornando a ISO 27001 uma opção inicial mais escalável.

5.4 Controles Gerais de TI (ITGC) e Controles de Aplicação (ITAC)

A auditoria de TI baseia-se na avaliação de duas classes fundamentais de controles:

Categoria	ITGC — Controles Gerais de TI	ITAC — Controles de Aplicação
Escopo	Infraestrutura ampla de TI (toda a organização)	Transações específicas de sistemas individuais
Exemplos	Controle de acesso biométrico, MFA, backups, gestão de mudanças	Validação de entrada, conciliação de totais, logs de exportação

6. CMM, CMMI e Maturidade de Processos

Os modelos de maturidade de processos surgiram da necessidade de avaliar e melhorar a capacidade das organizações de desenvolvimento de software de forma sistemática e mensurável.

6.1 Origem do CMM

Na década de 1980, as forças armadas dos Estados Unidos enfrentavam sérios problemas com atrasos e orçamentos estourados em softwares encomendados a fornecedores externos. Para resolver isso, o SEI (Software Engineering Institute) da Universidade Carnegie Mellon desenvolveu o CMM (Capability Maturity Model) para avaliar a capacidade dos fornecedores. O CMM focava exclusivamente em software.

6.2 Evolução para o CMMI

Com o tempo, percebeu-se que o desenvolvimento de software dependia de outras áreas, como hardware e engenharia de sistemas. Assim, nos anos 2000, o modelo evoluiu para o CMMI (CMM Integration), unificando diferentes modelos em uma única estrutura com cinco níveis de maturidade:

- Nível 1 — Inicial: processos caóticos e imprevisíveis.
- Nível 2 — Gerenciado: processos planejados e executados conforme políticas definidas.
- Nível 3 — Definido: processos descritos por padrões, procedimentos e métodos organizacionais.
- Nível 4 — Quantitativamente Gerenciado: processos controlados usando dados estatísticos.
- Nível 5 — Otimizado: foco em melhoria contínua e inovação incremental.

O CMMI V2.0 (SEI, 2018) trouxe atualizações com foco na melhoria contínua do desempenho do negócio e na integração com práticas ágeis modernas como Scrum e DevOps.

7. MPS.BR, SPICE e Normas de Qualidade

7.1 O Projeto SPICE e as Normas ISO

O projeto SPICE (Software Process Improvement and Capability Determination) nasceu nos anos 1990 como uma iniciativa internacional para criar um padrão unificado de avaliação de processos de software, dando origem posterior à norma ISO/IEC 15504 (atual família ISO/IEC 33000). Essas normas estabelecem uma base global para medição de capacidade e melhoria de processos.

7.2 O MPS.BR

No Brasil, implementar modelos internacionais como o CMMI era extremamente caro e complexo para a maioria das empresas nacionais, compostas predominantemente por pequenas e médias equipes. Por isso, em 2003, a SOFTEX criou o MPS.BR (Melhoria de Processo do Software Brasileiro).

O MPS.BR é totalmente baseado nas normas ISO/IEC 12207 e no SPICE, mas com uma divisão em sete níveis de maturidade (de G a A) para permitir que as empresas nacionais evoluíssem gradualmente com custos acessíveis:

- G — Parcialmente Gerenciado
- F — Gerenciado
- E — Parcialmente Definido
- D — Largamente Definido
- C — Definido
- B — Gerenciado Quantitativamente
- A — Em Otimização

8. Auditoria no Ciclo de Vida de Desenvolvimento de Software (SDLC)

O SDLC (Software Development Life Cycle) compreende a metodologia sistemática e iterativa que divide a criação de software em fases interdependentes. A auditoria desempenha papel crítico em cada marco do SDLC, verificando a eficácia dos controles organizacionais em todas as etapas.

8.1 Fases do SDLC e Checkpoints de Auditoria

Fase	O que a Auditoria Verifica	Controles Avaliados
1. Planejamento	Análise de custo-benefício e viabilidade estratégica	Alinhamento com objetivos de negócio
2. Requisitos	Requisitos de segurança e conformidade	Modelagem de ameaças e requisitos de privacidade
3. Projeto	Arquitetura de controles de acesso e criptografia	Segregação de funções (SoD)
4. Desenvolvimento	Revisão de código e padrões de desenvolvimento seguro	SAST e gestão de dependências
5. Testes	Testes de segurança e documentação	DAST e aceitação de sistemas
6. Implantação	Aprovação de mudanças e gestão de deploy	Gestão de mudanças corporativas
7. Manutenção	Monitoramento e gestão de incidentes	SIEM, patches e plano de continuidade (PCN)

8.2 DevSecOps e Auditoria Contínua

Com a transição acelerada para o DevSecOps, a segurança passou a ser embutida de forma contínua em todo o ciclo de desenvolvimento por meio do Secure SDLC (SSDLC). Nesse modelo, a auditoria deixa de acontecer apenas no final do projeto e passa a ser realizada de forma integrada ao pipeline de CI/CD (Integração e Entrega Contínua).

A auditoria em ambientes DevSecOps verifica: uso de ferramentas de análise de vulnerabilidades, controle de acesso aos ambientes, gestão de segredos e credenciais, registro das alterações feitas no sistema e que apenas código aprovado seja implantado em produção.

8.3 Controles Críticos no SDLC

Dentre os controles mais relevantes verificados pela auditoria no ciclo de vida do software, destacam-se:

- **Segregação de Funções (SoD):** os desenvolvedores que escrevem o código não devem ter permissão para aprová-lo e implantá-lo em produção, mitigando o risco de sabotagem intencional.
- **Aceitação de Sistemas:** o auditor avalia se o sistema cumpre os critérios formais de validação operacional antes da transferência para produção.
- **Descarte Seguro de Mídias:** validação de procedimentos para destruição física, trituração ou desmagnetização de dispositivos de armazenamento, com emissão de Certificado de Destruição (CoD).

- Continuidade de Negócios (PCN): avaliação do plano de recuperação, incluindo políticas, Análise de Impacto ao Negócio (BIA) e testes periódicos de controles preventivos.

9. Análise Crítica da Auditoria de Sistemas

9.1 Desafios de Implementação

A implementação de processos de auditoria enfrenta diversos obstáculos. A rápida evolução tecnológica exige atualização constante dos profissionais. Ambientes em nuvem, virtualização, inteligência artificial, internet das coisas e arquiteturas distribuídas aumentam significativamente a complexidade das verificações. Outro desafio está relacionado ao custo de aquisição de ferramentas especializadas e à contratação de profissionais qualificados.

Em muitas empresas existe ainda resistência das equipes técnicas, que enxergam a auditoria como mecanismo punitivo em vez de atividade de melhoria contínua — percepção que precisa ser combatida por meio de comunicação e engajamento organizacional.

9.2 Limitações do Processo

Mesmo sendo essencial, a auditoria apresenta limitações intrínsecas. A análise costuma depender da qualidade dos registros e documentos disponíveis. Logs incompletos, ausência de padronização e falhas na rastreabilidade dificultam a obtenção de evidências confiáveis. Auditorias executadas apenas em intervalos periódicos podem deixar de identificar incidentes ocorridos entre avaliações. Há também o risco de conclusões equivocadas quando a amostragem utilizada não representa adequadamente o ambiente auditado.

9.3 Riscos de Não Conformidade

A não conformidade pode resultar em impactos financeiros, jurídicos e reputacionais severos. O descumprimento de requisitos relacionados à proteção de dados, segurança da informação e continuidade operacional pode ocasionar multas, perda de contratos, ações judiciais e redução da confiança dos clientes. Além disso, vulnerabilidades não identificadas podem facilitar ataques cibernéticos, vazamentos de informações e indisponibilidade de serviços críticos.

9.4 Auditoria Tradicional vs. Auditoria Contínua

Critério	Auditoria Tradicional	Auditoria Contínua
Periodicidade	Anual / Semestral	Tempo real
Coleta de evidências	Manual	Automatizada

Detecção de falhas	Retrospectiva	Imediata
Adequação ao ágil	Baixa	Alta
Custo inicial	Menor	Maior
Integração DevOps	Limitada	Nativa (CI/CD e SIEM)

Organizações que operam em ambientes altamente dinâmicos podem obter melhores resultados ao combinar técnicas tradicionais com mecanismos contínuos de monitoramento, equilibrando conformidade, eficiência operacional, agilidade e capacidade de resposta.

10. Estudo de Casos Práticos

Os dois casos a seguir ilustram situações reais de falhas nos controles de TI, demonstrando as consequências da ausência de boas práticas de auditoria e as lições que delas podem ser extraídas.

10.1 Caso 1 — Fraude Fiscal por Manipulação de Notas Fiscais

Descrição do Caso

Em um caso emblemático de fraude corporativa no cenário tributário brasileiro, o gerente financeiro de uma rede varejista adulterou intencionalmente o valor e o registro de notas fiscais de venda diretamente nos bancos de dados da empresa, com o objetivo de sonegar o pagamento de ICMS. Sob a ótica da auditoria interna e da norma NBC TI, a ação configurou-se como fraude — distorção intencional de registros para ganho ilícito — e não como mero erro operacional, demonstrando falhas graves nos controles internos de processamento de dados.

Classificação Normativa

A norma NBC TI diferencia fraude de erro com base no elemento volitivo: ausência de intenção equivale a erro; presença de intenção equivale a fraude. No caso em questão, a conduta foi tipificada como fraude, pois há intenção deliberada de distorcer registros para obter vantagem ilícita.

Limitações dos Sistemas Tradicionais e o Papel da IA

A investigação evidenciou as limitações dos sistemas SIEM (Security Information and Event Management) baseados em regras estáticas de controle. Fraudadores internos refinam continuamente suas táticas para contornar limites preestabelecidos, visando principalmente contas com credenciais administrativas para apagar trilhas de auditoria.

A implementação de soluções de inteligência artificial com aprendizado adaptativo transforma a eficácia da auditoria. Diferentemente das regras fixas, os modelos de IA analisam continuamente padrões comportamentais de contas privilegiadas, reduzindo falsos positivos e permitindo que os auditores foquem em desvios reais. Para operações multinacionais, o aprendizado adaptativo ajusta os limites de detecção por contexto geográfico.

Lições Aprendidas

- Sistemas SIEM com regras estáticas são insuficientes para detectar fraudes internas refinadas.
- A IA adaptativa reduz falsos positivos e direciona o esforço do auditor para anomalias reais.
- Contas com privilégios administrativos devem ter monitoramento comportamental intensificado.
- O aprendizado por contexto geográfico é indispensável em operações multinacionais.

10.2 Caso 2 — Falhas de Conformidade com a LGPD

Descrição do Caso

Uma empresa de tecnologia identificou falhas graves de rastreabilidade em seus registros de sistema. Eventos locais de servidores, logs de conexões externas de firewalls e acessos a dados em suítes de produtividade na nuvem estavam espalhados em repositórios desvinculados, impossibilitando uma visão consolidada das atividades de acesso.

A falta de um inventário de hardware atualizado permitiu que dispositivos não autorizados se conectassem à rede sem cruzamento de logs correspondentes.

Exposição à LGPD

Esse cenário gerou exposição crítica perante a Lei Geral de Proteção de Dados (LGPD — Lei 13.709/2018), que impõe a obrigação de demonstrar de forma clara, em caso de incidente ou requisição de titular, quem acessou dados pessoais, quando e com qual finalidade regulamentar. Sem um repositório centralizado e imutável, a empresa não conseguia correlacionar eventos entre sistemas distintos, criando pontos cegos críticos para a auditoria de segurança.

Lições Aprendidas e Ações Corretivas

- Logs fragmentados inviabilizam a resposta a incidentes e a conformidade com a LGPD.
- O inventário de ativos de TI deve ser atualizado em tempo real e cruzado com logs de acesso.

- Um repositório centralizado e imutável (ex.: SIEM com armazenamento append-only) é requisito mínimo.
- A LGPD exige que a organização comprove a finalidade e legitimidade de cada acesso a dados pessoais.
- Dispositivos não gerenciados representam vetor crítico de vazamento de dados.

11. Conclusão

A evolução da auditoria de sistemas de informação consolida sua posição como instrumento indispensável de governança, blindagem operacional e garantia de conformidade legal. As organizações não podem mais tratar a tecnologia como um departamento isolado: ela constitui o próprio motor transacional que viabiliza a geração de valor e a relação de confiança com clientes e parceiros de negócios.

Este trabalho demonstrou que a auditoria de sistemas abrange dimensões técnicas, jurídicas e comportamentais, exigindo do auditor moderno uma visão integradora que combine conhecimento de frameworks como COBIT 2019, ISO 27001 e NIST com a capacidade de avaliar controles específicos como a segregação de funções, a gestão de logs e a conformidade com normas como a LGPD e a Lei SOX.

A transição para abordagens de auditoria contínua, integradas aos pipelines de DevSecOps, representa o caminho mais eficaz para organizações que operam em ambientes altamente dinâmicos. A combinação de técnicas tradicionais com ferramentas modernas — como IA adaptativa e SIEM centralizado — permite equilibrar conformidade, eficiência operacional e agilidade de resposta frente aos riscos emergentes.

Por fim, recomenda-se às organizações: integrar o modelo SSDLC ao ciclo de desenvolvimento; implementar rigorosamente a segregação de funções; modernizar o monitoramento de logs com inteligência artificial; e fortalecer continuamente os programas de conscientização humana em segurança da informação.

12. Referências Bibliográficas

ATTIE, William. Auditoria: Conceitos e Aplicações. São Paulo: Atlas, 2018.

CANNAVALE, Alessandro. Evolução Histórica da Auditoria de Tecnologia da Informação. Revista de Auditoria e Governança de TI, v. 4, n. 2, 2021.

CHRISSIS, Mary Beth; KONRAD, Mike; SHRUM, Sandy. CMMI: Guidelines for Process Integration and Product Improvement. Boston: Addison-Wesley, 2011.

COSO. Internal Control — Integrated Framework. Committee of Sponsoring Organizations of the Treadway Commission, 2013.

HUMPHREY, Watts S. Managing the Software Process. SEI Series in Software Engineering. Reading: Addison-Wesley, 1989.

IMONIANA, Joshua Onome. Auditoria de Sistemas de Informação. São Paulo: Atlas, 2016.

ISACA. COBIT 2019 Framework: Governance and Management Objectives. Rolling Meadows: ISACA, 2018.

ISACA. ITAF: A Professional Practices Framework for IT Audit. 4. ed. Rolling Meadows: ISACA, 2020.

ISO/IEC 27001:2022. Information Security Management Systems — Requirements. Genebra: ISO, 2022.

ISO/IEC 33001:2015. Information Technology — Process Assessment — Concepts and Terminology. Genebra: ISO, 2015.

GALLOWAY, Glenn. Modern Techniques in IT Auditing. Journal of Corporate Accounting & Finance, 2022.

REZENDE, Denis Alcides. Engenharia de Software e Sistemas de Informação. Rio de Janeiro: Brasport, 2011.

ROCHA, Ana Regina; SANTOS, Gleison; BARRETO, Avelino. Qualidade de Software: Teoria e Prática. São Paulo: LTC, 2013.

SOFTWARE ENGINEERING INSTITUTE (SEI). Capability Maturity Model Integration (CMMI) for Development, Version 2.0. Pittsburgh: CMU/SEI, 2018.

SOFTEX. MPS.BR — Melhoria de Processo do Software Brasileiro: Guia Geral. Brasília: SOFTEX, 2021.

UNITED STATES. Sarbanes-Oxley Act of 2002. Pub. L. 107-204, 116 Stat. 745.

BRASIL. Lei n. 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília: Presidência da República, 2018.